

DOCUMENTACIÓN TÉCNICA PROFESIONAL

Ataque DHCP Spoofing — Servidor DHCP Falso (Rogue DHCP)

Autor	Emmanuel Orlando Rodriguez
Matrícula	2025-0798
Asignatura	Seguridad en Redes
Fecha	Junio 2026
Script	EmmanuelRodriguez_2025-0798_dhcp_spoofing_P2.py

1. Objetivo del Laboratorio

El presente laboratorio tiene como objetivo demostrar de forma práctica cómo un atacante puede desplegar un servidor DHCP falso (Rogue DHCP Server) en la red para interceptar las solicitudes legítimas de configuración IP de las víctimas.

Se busca evidenciar cómo el protocolo DHCP, al carecer de mecanismos de autenticación, puede ser explotado para asignar a las víctimas una configuración de red maliciosa donde el gateway y el servidor DNS apuntan a la máquina del atacante (Kali Linux), posicionándola como intermediario de todo el tráfico (Man in the Middle).

2. Objetivo del Script

El script dhcp_spoofing.py tiene como objetivo escuchar las peticiones DHCP Discover en la red y responder antes que el servidor legítimo, entregando a las víctimas una configuración IP falsa. Como resultado, todo el tráfico de red de las víctimas es redirigido a través de Kali Linux, permitiendo la captura y análisis de información sensible.

2.1 Parámetros Usados

Parámetro	Valor	Descripción
IFACE	eth1	Interfaz de red del atacante conectada al switch
ATTACKER_IP	192.168.79.30	IP de Kali Linux (atacante/servidor DHCP falso)
SUBNET_MASK	255.255.255.0	Máscara de subred de la LAN
FAKE_GATEWAY	192.168.79.30	Gateway falso → apunta a Kali (posiciona MitM)
FAKE_DNS	192.168.79.30	DNS falso → apunta a Kali (permite DNS Spoofing)

IP_POOL	.200 – .220	Rango de IPs falsas asignadas a las víctimas
LEASE_TIME	300 seg	Tiempo de arrendamiento de la IP asignada

2.2 Requisitos para Utilizar la Herramienta

- Sistema operativo: Kali Linux
- Python 3.x instalado
- Librería Scapy: `sudo apt install python3-scapy`
- Permisos de root (sudo)
- Conectividad de capa 2 con las víctimas (misma subred)
- El servidor DHCP legítimo (R1) debe estar apagado o responder más lento que Kali

3. Documentación del Funcionamiento del Script

El script opera en modo pasivo-activo: escucha el tráfico DHCP de la red y responde a cada solicitud con paquetes DHCP falsificados que posicionan a Kali como gateway y DNS de las víctimas.

Paso 1 — Captura de peticiones DHCP Discover

El script usa `sniff()` de Scapy con un filtro BPF para capturar únicamente tráfico UDP en los puertos 67 y 68 (DHCP). Cada paquete capturado es procesado por la función `handle_dhcp_packet()`.

```
sniff(iface=IFACE, filter='udp and (port 67 or port 68)',  
prn=handle_dhcp_packet, store=False)
```

Paso 2 — Asignación de IP falsa

Cuando se detecta un DHCP Discover (`message-type=1`), el script verifica si ya asignó una IP a esa MAC. Si no, toma la siguiente IP disponible del pool (.200-.220) y la registra en el diccionario de leases.

```
leases[client_mac] = get_next_ip()
```

Paso 3 — Envío de DHCP Offer falso

Se construye y envía un paquete DHCP Offer con la IP asignada al cliente, pero con Kali como gateway y DNS. Si este paquete llega antes que el servidor legítimo, la víctima lo acepta.

```
offer = Ether()/IP()/UDP()/BOOTP(yiaddr=offered_ip)/DHCP(options=[("router",  
FAKE_GATEWAY), ("name_server", FAKE_DNS)])
```

Paso 4 — Confirmación con DHCP ACK

Cuando la víctima envía un DHCP Request (`message-type=3`) aceptando la oferta, el script responde con un DHCP ACK confirmando la asignación. A partir de este momento la víctima queda configurada con Kali como gateway.

```
ack = BOOTP(yiaddr=acked_ip)/DHCP(options=[("message-type","ack"), ("router",  
FAKE_GATEWAY)])
```

Paso 5 — Intercepción del tráfico

Con la víctima configurada, todo su tráfico pasa obligatoriamente por Kali antes de llegar al gateway real. Usando Wireshark en Kali se puede observar en tiempo real contraseñas, cookies y cualquier dato no cifrado.

Impacto del ataque

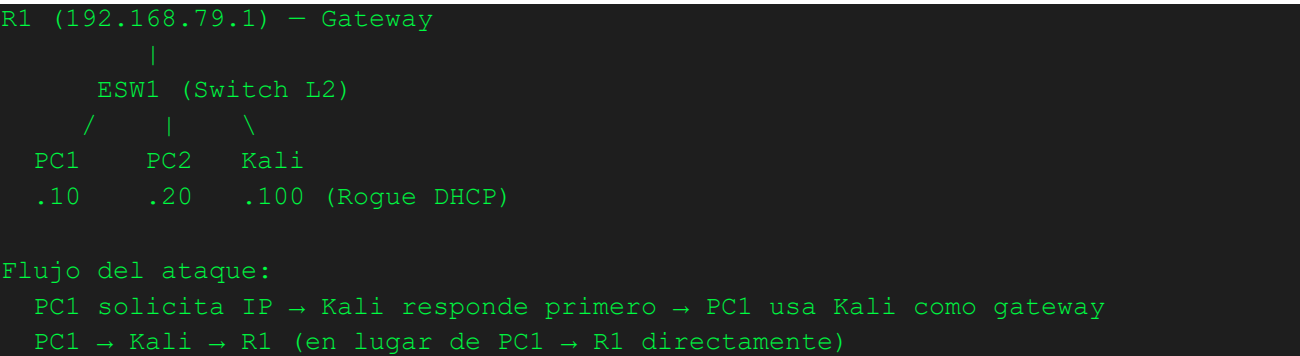
Todo el tráfico de PC1 y PC2 pasa por Kali antes de llegar al gateway real. El atacante puede ver contraseñas, cookies, consultas DNS y cualquier dato en texto plano. La víctima no nota ninguna diferencia en la conectividad ya que Kali reenvía los paquetes normalmente (con IP Forwarding activo).

4. Documentación de la Red

4.1 Topología de Red

La topología fue construida en GNS3 utilizando imágenes Cisco c3725. La red opera en una única subred 192.168.79.0/24 sin VLANs.

Diagrama de topología



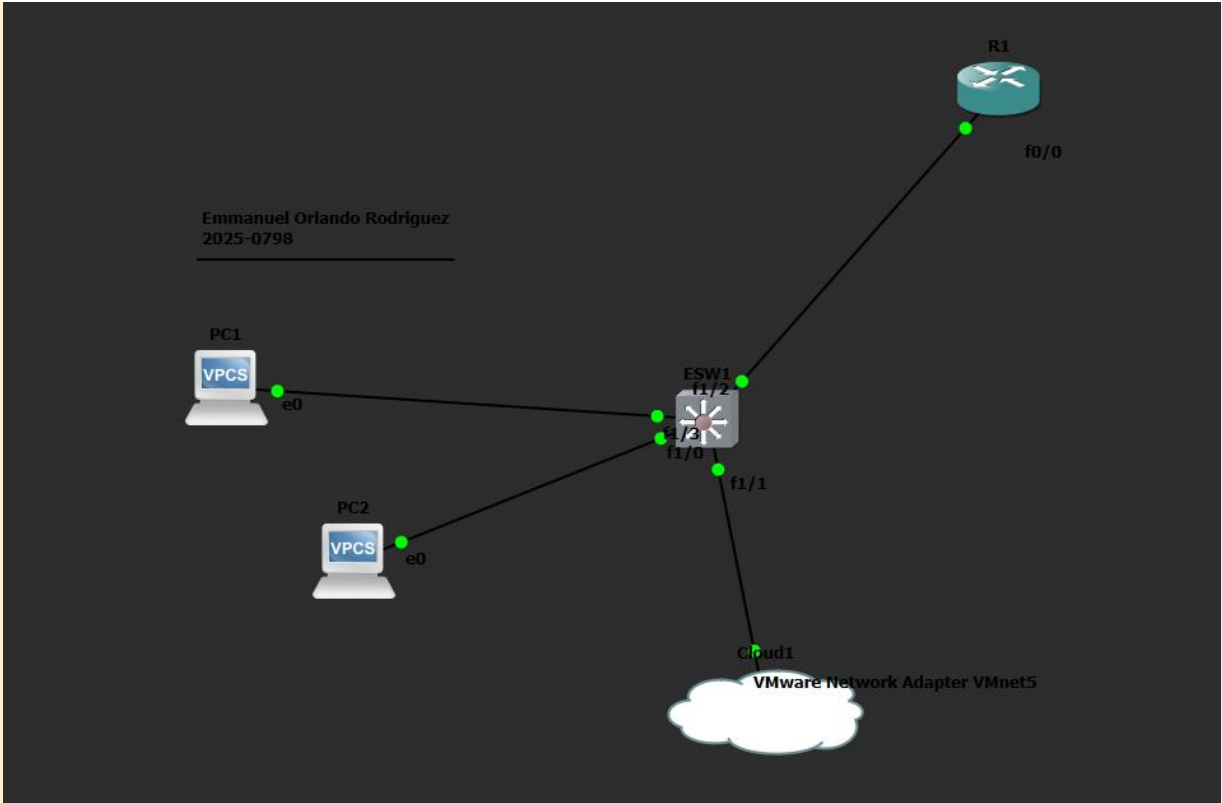
4.2 Direccionamiento IP

Dispositivo	IP	MAC	Rol
Router R1	192.168.79.1	c2:02:4c:34:00:00	Gateway
PC1 (Víctima)	192.168.79.10	00:50:79:66:68:00	Víctima principal
PC2	192.168.79.20	00:50:79:66:68:01	Víctima secundaria
Kali Linux	192.168.79.30	00:0c:29:18:51:86	Atacante / DHCP falso

4.3 Interfaces y Conexiones

Dispositivo A	Puerto A	Dispositivo B	Puerto B
ESW1	fa1/2	R1	fa0/0
ESW1	fa1/1\3	PC1	e0
ESW1	fa1/0	PC2	e0
ESW1	fa1/1	Kali Linux	VMnet5

5. Capturas de Pantalla



Captura 2 — Script dhcp_spoofing.py ejecutándose en Kali:

```

$ sudo python3 dhcp-spoofing.py
[sudo] password for kali:
Ataque DHCP Spoofing - Servidor DHCP Falso (Rogue DHCP)
Autor : Emmanuel Orlando Rodriguez
Matricula: 2025-0798

[+] Interfaz : eth1
[+] MAC Atacante : 00:0c:29:18:51:86
[+] IP Atacante : 192.168.79.30
[+] Gateway Falso : 192.168.79.30 (+ Kali, MitM)
[+] DNS Falso : 192.168.79.30 (+ Kali)
[+] Pool de IPs : 192.168.79.200 - 192.168.79.220
[+] Lease Time : 300 segundos

[*] Escuchando peticiones DHCP... (Ctrl+C para detener)

[*] DHCP Discover recibido de 00:50:79:66:68:00
[+] DHCP Offer enviado -> IP: 192.168.79.200 | GW: 192.168.79.30 | DNS: 192.168.79.30

[*] DHCP Discover recibido de 00:50:79:66:68:03
[+] DHCP Offer enviado -> IP: 192.168.79.201 | GW: 192.168.79.30 | DNS: 192.168.79.30

```

6. Contramedidas

Las contramedidas para DHCP Spoofing se basan en validar la autenticidad de los paquetes DHCP o en garantizar que solo los puertos de red autorizados puedan enviar respuestas DHCP.

6.1 Contramedida 1 — DHCP Snooping en el Switch (la más robusta)

El switch valida cada paquete DHCP contra una tabla de puertos de confianza. Solo los puertos marcados como trusted (donde está el servidor legítimo) pueden enviar respuestas DHCP. Cualquier respuesta que venga de un puerto untrusted (donde está Kali) es descartada automáticamente.

¿Qué hace cada comando?

- `ip dhcp snooping` — Activa la inspección de paquetes DHCP globalmente en el switch.
- `ip dhcp snooping vlan 1` — Aplica la inspección en la VLAN 1 donde están todos los dispositivos.
- `ip dhcp snooping trust` (en fa1/2 hacia R1) — Marca ese puerto como confiable. Solo desde aquí se permiten respuestas DHCP.
- Todos los demás puertos quedan untrusted — El switch descarta cualquier DHCP Offer o ACK que llegue del puerto de Kali.

```
ESW1(config)# ip dhcp snooping
ESW1(config)# ip dhcp snooping vlan 1
ESW1(config)# interface fastEthernet 1/2
ESW1(config-if)# ip dhcp snooping trust
ESW1(config-if)# exit
```

Nota: Esta contramedida no es compatible con el c3725 en modo local de GNS3. Requiere hardware real (Cisco Catalyst 3550/3560/3750) o imágenes IOSv L2.

6.2 Contramedida 2 — Servidor DHCP Legítimo Activo en R1 (aplicada en nuestra topología)

Si R1 tiene su servidor DHCP activo y responde más rápido que Kali, las víctimas recibirán la configuración legítima. Esta es la contramedida más práctica de demostrar en GNS3 con c3725.

```
R1(config)# service dhcp
R1(config)# ip dhcp pool LAN
R1(dhcp-config)# network 192.168.79.0 255.255.255.0
R1(dhcp-config)# default-router 192.168.79.1
R1(dhcp-config)# dns-server 8.8.8.8
R1(dhcp-config)# lease 0 0 5
R1(dhcp-config)# exit
```

Efecto: Las víctimas reciben IP del rango legítimo (.10–.50) con R1 como gateway real, en lugar de las IPs falsas de Kali (.200–.220).

6.3 Contramedida 3 — IP Estática en las Víctimas

Si las víctimas tienen IP estática configurada, nunca envían DHCP Discover y el ataque no tiene ningún efecto, ya que no hay solicitud que interceptar.

```
PC1> ip 192.168.79.10/24 192.168.79.1
PC2> ip 192.168.79.20/24 192.168.79.1
```

6.4 Comparación de Contramedidas

Contramedida	Efectividad	Dificultad	Compatible GNS3
DHCP Snooping en switch	Muy alta	Media	No (c3725)
DHCP legítimo activo en R1	Alta	Baja	Sí
IP estática en víctimas	Alta	Baja	Sí (manual)